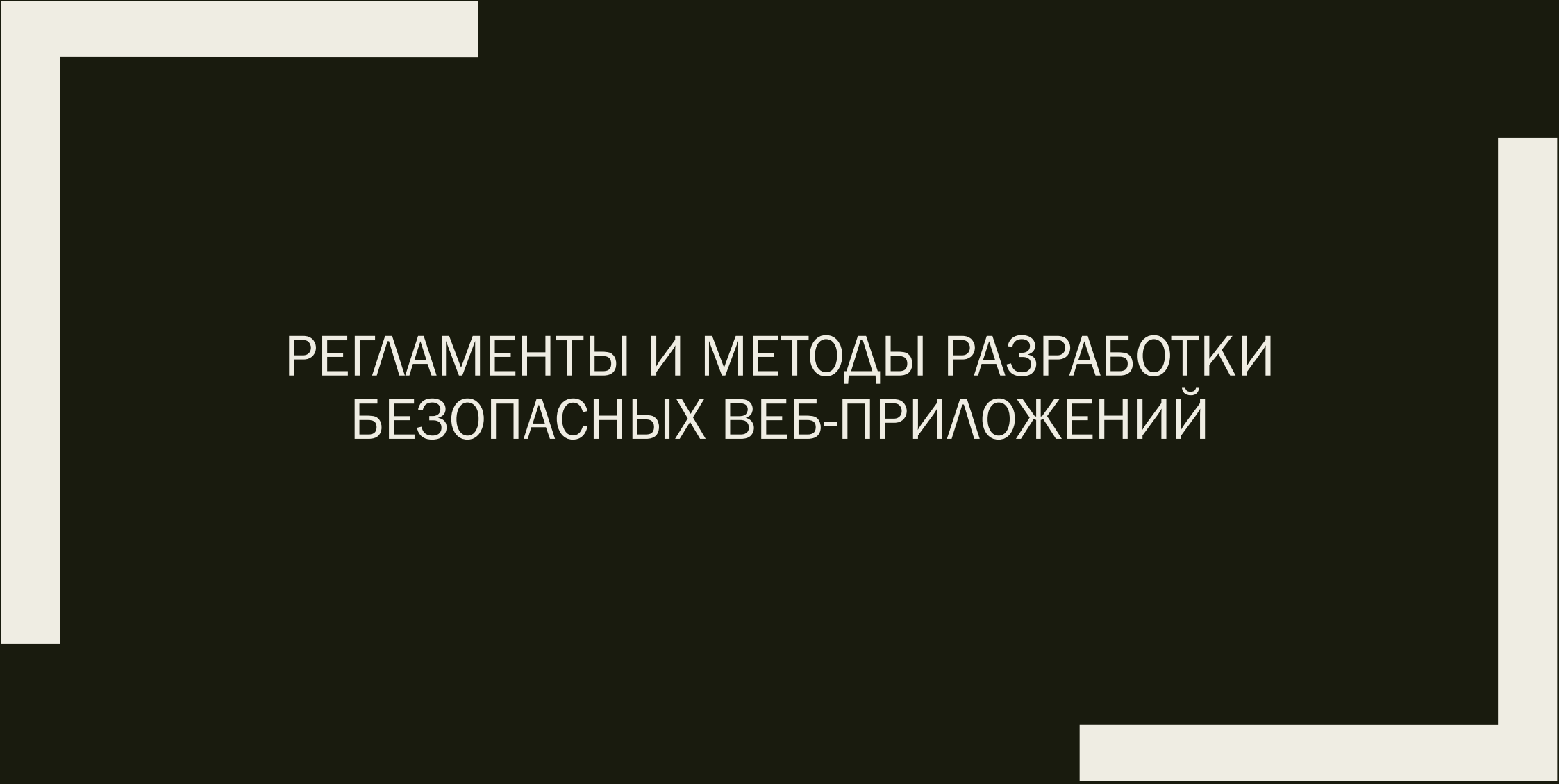




РЕГЛАМЕНТЫ И МЕТОДЫ РАЗРАБОТКИ БЕЗОПАСНЫХ ВЕБ-ПРИЛОЖЕНИЙ

Защита данных — Общий регламент по защите данных (GDPR)

Общий регламент по защите данных (GDPR), принятый 14 апреля 2016 г. и опубликованный в Официальном вестнике ЕС 4 мая 2016 г., применяется во всех странах-членах ЕС с 25 мая 2018 г. Он отменяет и заменяет Директиву 95/46/ЕС и имплементирующее законодательство ее стран-членов.

В основе правил Общего регламента по защите данных (GDPR) лежит концепция подотчетности — это означает, что организации в пределах ЕС или вне ЕС, которые ориентированы на резидентов ЕС, должны, в соответствии с GDPR, повысить прозрачность и добросовестность при работе с персональной информацией частного лица. Персональная информация здесь означает любую информацию в отношении идентифицируемого частного лица (указанного в регламенте как субъект данных).

Персонал

В соответствии с правилами Общего регламента по защите данных (GDPR), все сотрудники обязаны придерживаться положений о конфиденциальности данных.

Сбор данных

Персональные данные будут собираться только при условии их добровольного предоставления, например, посредством заполнения форм или отправки писем по электронной почте в рамках заказа продуктов или услуг, или посредством обращений или запросов информационных материалов. База данных и ее содержимое остается в компании и у поставщика услуг. Тем не менее, персональные данные ни в коем случае не будут перенаправлены каким-либо третьим лицам или любой стороной, уполномоченной, если только: пользователь не дал согласие на это; это находится в рамках выполнения контрактных обязательств; они предназначены для информирования клиентов, бизнес-партнеров и/или поставщиков услуг, или если они нужны для выполнения юридических обязательств в связи со статьей 6, параграф 1, пункт «с» Общего регламента по защите данных (GDPR).

Сбор данных

От представителей компаний клиентов и партнеров можно требовать всю или часть следующей персональной информации, в зависимости от конкретной страны-члена зоны возмещения, и необходимую документацию: базовая персональная информация, т. е. фамилия, контактные данные, копия паспорта и адрес (в случае компании с одним владельцем).

Сбор данных

Веб-портал можно посещать без предоставления каких-либо персональных данных. Однако, при открытии веб-сайта некоторые данные сохраняются для целей резервного копирования — такие как **название вашего интернет-провайдера, веб-сайт, с которого вы перешли на наш веб-сайт и ваш IP-адрес**. Эти данные, возможно, могут помочь в идентификации, тем не менее, не следует использовать их в отношении отдельных частных лиц. Эти данные **могут анализироваться в целях статистики, но каждый отдельный пользователь всегда остается анонимным**.

Использование куки-файлов

Дополнительно к вышеуказанному, временные куки-файлы сохраняются на компьютере при использовании веб-сайта. Куки-файлы являются небольшими текстовыми файлами, которые сохраняются на жестком диске браузером, который использует клиент, и посредством которых осуществляется отправка информации стороной, которая устанавливает куки-файлы. Эти куки-файлы предназначены для большего удобства использования и большей эффективности веб-сайта, и они не могут выполнять программы или загружать вирусы на ваш компьютер.

Использование куки-файлов

Некоторые куки-файлы необходимы для эффективного использования сайта, но если вы не хотите, чтобы куки-файлы сохранялись на ваш компьютер, вы можете задать в настройках вашего браузера отклонение всех куки-файлов до осуществления доступа к веб-сайту. Большинство браузеров предоставляет вам возможность выбора приема или отклонения куки-файлов. Однако, обратите внимание на то, что некоторые функции в результате этого могут быть недоступны. Используя веб-сайт без деактивации приема куки-файлов, вы соглашаетесь на временную установку куки-файлов на ваш компьютер.

Используемые куки-файлы

Сейчас используются следующие категории куки-файлов:

1. Необходимые куки-файлы

Необходимые куки-файлы помогают сделать веб-сайт удобным посредством предоставления базовых функций, таких как навигация по страницам и доступ к защищенным зонам веб-сайта. Веб-сайт не может надлежащим образом функционировать без этих куки-файлов.

Используемые куки-файлы

2. Куки-файлы предпочтений

Куки-файлы предпочтений позволяют веб-сайту запоминать информацию, меняющую поведение или внешнее представление веб-сайта, — такую как ваш предпочитаемый язык или регион, в котором вы находитесь.

Используемые куки-файлы

3. Куки-файлы веб-аналитики

На веб-сайте используются различные инструменты для анализа поведения при просмотре на страницах. Главным из них является Google Аналитика, сервис веб-аналитики, предоставляемый Google Inc. («Google»). Использование осуществляется на основании статьи 6, параграф 1, пункт 1 (f) Общего регламента по защите данных (GDPR). Сгенерированная информация в отношении использования вами веб-сайта может включать:

- тип/версию браузера;
- используемую операционную систему;
- URL-адрес ссылающегося домена (предварительно посещенный веб-сайт);
- имя хоста компьютера, с которого осуществляется доступ (IP-адрес), и
- время запроса к серверу.

Эта информация в основном передается на сервер Google в США и хранится там же.

Цель и правовое основание для обработки

Персональные данные необходимо использоваться только для предоставления клиентам нужных продуктов и/или услуг или для других целей, для которых клиенты предоставили свое согласие, при условии, что это не противоречит каким-либо существующим правовым нормам. Это осуществляется в соответствии со статьей 6, параграф 1, пункт «b» Общего регламента по защите данных (GDPR).

Права субъектов данных

В случае, если вы обрабатываете персональные данные, полученные от клиентов, вы являетесь затронутым лицом в значении **Общего регламента по защите данных** и имеете следующие права в отношении вас, как ответственной стороны в значении GDPR:

Права субъектов данных

ПРАВО НА ИНФОРМИРОВАНИЕ

Клиент имеет право подать запрос на ознакомление с использованием ваших персональных данных. Он может включать требование о получении информации о конкретных реципиентах или категориях реципиентов, которым его персональные данные были или будут раскрыты, или требование об уточнении в отношении цели или длительности обработки.

Права субъектов данных

ПРАВО НА ВНЕСЕНИЕ ПОПРАВOK

Клиент имеет право на внесение поправок и/или предоставление полных данных, если обрабатываемые персональные данные в отношении него неточные или неполные. Для этого реализуйте связь с клиентом.

Права субъектов данных

ПРАВО НА ОГРАНИЧЕНИЕ ОБРАБОТКИ

Клиент может подать запрос **на ограничение обработки своих персональных данных**, если:

- ☐ он не согласен с правильностью персональных данных
- ☐ обработка незаконна;
- ☐ оператору (т. е. вашей компании) больше не нужны персональные данные для целей обработки;
- ☐ клиент возразил против обработки согласно статье 21, параграф 1 Общего регламента по защите данных в ожидании верификации, имеют ли приоритет законные основания оператора над вашими аргументами.

Если обработка персональных данных, касающихся пользователя, была ограничена, такие данные — кроме сохранения — могут быть обработаны только с его согласия или для цели заявления, выполнения или защиты прав, или защиты прав другого физического или юридического лица, или по причинам важного общественного интереса союза или страны-члена.

Если ограничение обработки было выполнено в соответствии с вышеуказанными условиями, вам необходимо уведомить клиента.

Права субъектов данных

ПРАВО НА УДАЛЕНИЕ (ПРАВО НА ЗАБВЕНИЕ)

У клиента есть право на **подачу запроса на удаление персональных данных** при условии наступления одной из следующих причин:

- ☐ персональные данные более не нужны в связи с целями, для которых они были собраны или обработаны другим способом;
- ☐ клиент отозвал ваше согласие, на основании которого осуществляется обработка в соответствии со статьей 6, параграф 1, пункт «а» или статьей 9, параграф 2 (а) Общего регламента по защите данных (GDPR) и если нет другой законной причины для обработки;
- ☐ персональные данные были обработаны незаконным способом;
- ☐ персональные данные необходимо удалить в соответствии с законными обязательствами в законодательстве союза или страны-члена

Права субъектов данных

ПРАВО НА ПЕРЕНОСИМОСТЬ ДАННЫХ

У клиента есть право на подачу запроса о передаче нами персональных данных в отношении него непосредственно другому ответственному лицу без каких-либо препятствий с нашей стороны, насколько это технически возможно.

Свободы и права других лиц не должны быть затронуты вашим запросом, и право на переносимость данных не применяется к обработке персональных данных, необходимых для выполнения задачи в общественных интересах или при осуществлении официального полномочия, предоставленного ответственной стороне.

Права субъектов данных

ПРАВО ОБЖАЛОВАНИЯ В НАДЗОРНОМ ОРГАНЕ

Не отказываясь от любых других административных или юридических средств защиты, у клиента есть право обжалования в надзорном органе, в частности, в стране-члене, в которой вы являетесь резидентом или работаете, или подозревается нарушение, если клиент считает, что обработка персональных данных в отношении него находится в противоречии с общим регламентом по защите данных.

Хранение данных

Не учитывая любые существующие требования законодательства, такие как текущие процессуальные действия и т. д., вы должны **сохранять персональные данные до тех пор, пока они будут нужны для выполнения требуемой услуги**, на которую клиент дал свое согласие. Его данные будут полностью удалены из базы данных после завершения договорных соглашений.

Проектирование безопасности

Принципы безопасных архитектуры и дизайна:

- ❑ простота механизмов (economy of mechanism);
- ❑ безопасность по умолчанию (fail-safe defaults);
- ❑ полное проникновение защиты (complete mediation);
- ❑ открытый дизайн (open design);
- ❑ разделение полномочий (separation of privilege);
- ❑ минимум привилегий (least privilege);
- ❑ минимизация разделения ресурсов (least common mechanism);
- ❑ психологическая приемлемость (psychological acceptability).

Заключение

Простую программу сделать безопасной очень легко. Для этого не надо много думать, планировать: на безопасность надо только немного обратить внимание, применить практики безопасного программирования.

Задумываясь о дизайне средней по сложности программы, вы сэкономите себе много времени, денег и, возможно, сохраните свою репутацию.

Качественная архитектура и дизайн сложной программы — единственный способ сделать ее безопасной.

Вспомните об этом, когда следующий раз будете планировать новую программу или рефакторинг уже существующей.